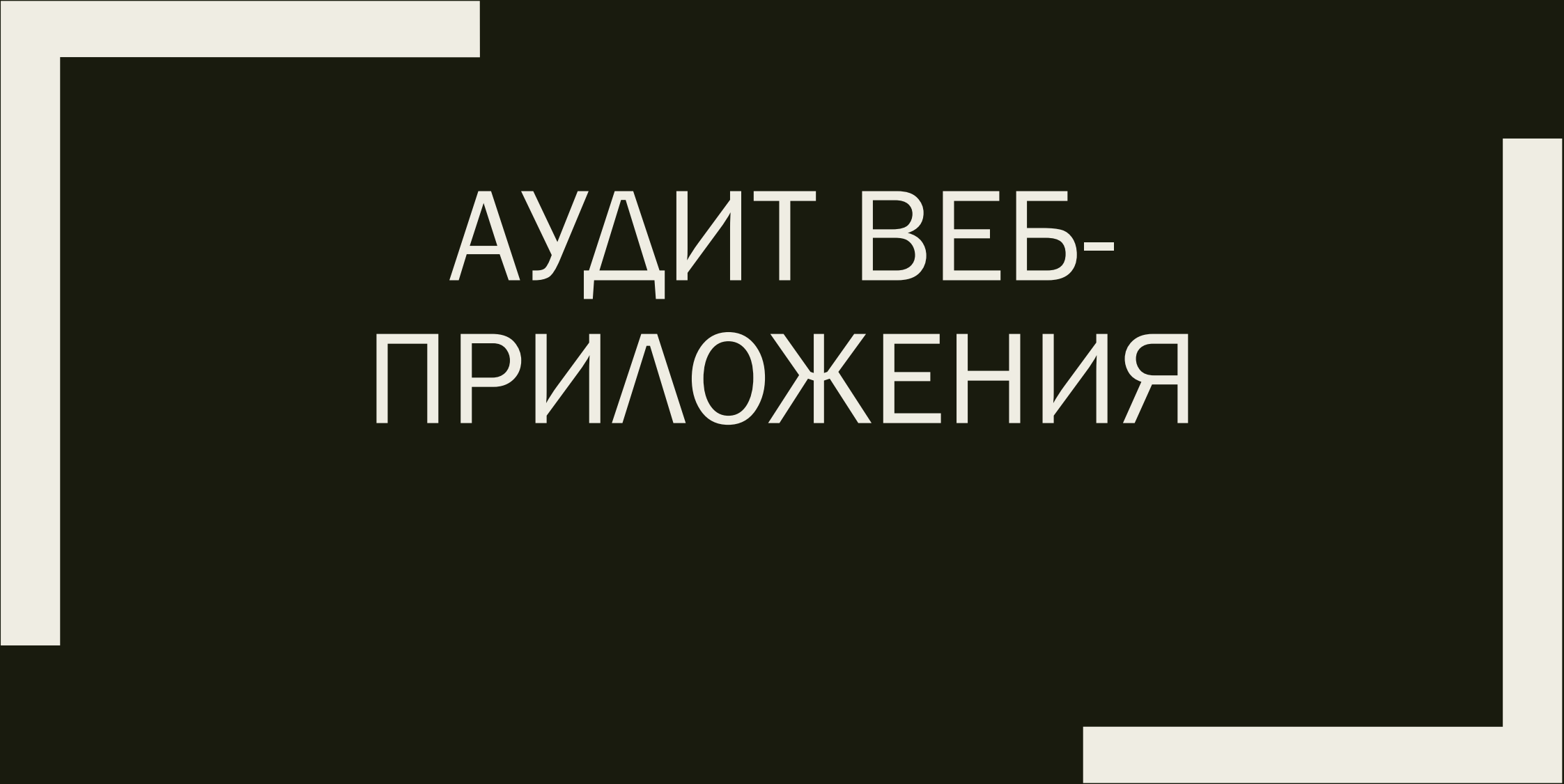


A decorative frame composed of two thick, white L-shaped lines. One line starts at the top-left and extends horizontally to the right, then vertically down. The other line starts at the bottom-right and extends horizontally to the left, then vertically up. They meet at the center, framing the text.

АУДИТ ВЕБ- ПРИЛОЖЕНИЯ

BlackBox — «черный ящик»

Одним из методов аудита веб-сайта является тестирование на проникновение BlackBox (BlackBox — «черный ящик»), при котором специалист располагает только общедоступной информацией о цели исследования.

BlackBox — «черный ящик»

В данном методе используется модель внешнего злоумышленника, мотивированного на взлом некого веб-сайта для извлечения коммерческой выгоды или из хулиганских побуждений. Об исследуемой системе обычно заранее ничего, кроме названия компании и адреса веб-сайта, неизвестно. Подтверждение аудита может происходить разными способами — как информационным письмом с указанием объекта аудита (и исключений), так и с помощью специальных маркеров непосредственно на атакуемом сайте.

Для полной картины атаки на сайт и действий сотрудников служб ИТ/ИБ отделов крайне не рекомендуется ставить последних в известность. Этим заказчик может проверить готовность своих сотрудников к реагированию на инциденты ИБ.

Основные задачи тестирования

Основные задачи тестирования на проникновение:

- анализ и проверка безопасности архитектуры Web-сервера;
- выявление, оценка и попытка эксплуатации (по согласованию с заказчиком) всех возможных уязвимостей в Web-приложении;
- описание векторов атаки и оценка рисков;
- предоставление рекомендаций по улучшению информационной безопасности Web-приложения.

Основные задачи злоумышленника

Основные задачи злоумышленника:

- получения доступа к критичным данным;
- выведение сайта из строя;
- монетизация/профит.

Несмотря на расхождение целей, большинство методов работы злоумышленника и пентестера совпадают. При атаке злоумышленник обычно не придает особого значения морально-этическим нормам, такая атака может привести к необратимым деструктивным последствиям. При аудите легитимным пентестером согласуются наличие резервных копий и риск деструктивных последствий сводится к минимальному (особенно если у заказчика есть возможность развернуть тестовый стенд).

Злоумышленники обычно идут по пути от простого к сложному: выявляют явные уязвимости с помощью популярных утилит и сканеров и пытаются эксплуатировать выявленные уязвимости. Параллельно могут проводить фишинговые атаки с рассылкой вредоносных файлов или ссылок. **Основная цель** — с минимальными усилиями получить необходимые данные.

Основные методы аудита

Основные методы аудита похожи на действия злоумышленника и включают в себя:

- Разведку и сбор информации об атакуемой системе: в ход идут специальные поисковые запросы (google dork), обнаружение почтовых адресов сотрудников, профилей компании на сайтах вакансий (по вакансиям можно определить используемые технологии), поиск информации в кеше поисковиков, сканирование портов;
- Выявление защитных средств сайта — IDS/IPS/AntiDDoS/WAF систем;
- Сканирование веб-приложения популярными утилитами и сканерами — здесь достаточно широкий выбор, как платных, так и бесплатных программ;
- Сканирование директорий веб-сайта для поиска чувствительной информации (файлы, бэкапы базы данных и прочее) — к примеру утилитой dirbuster;
- Ручной анализ уязвимостей — с помощью проксирующих средств происходит обработка запросов и анализ на предмет наличия потенциальных уязвимостей.

Этапы аудита

Эти методы включают в себя следующие этапы:

- Пассивный сбор информации;
- Определение веб-окружения и платформы;
- Определение типа CMS;
- Сканирование портов/сбор баннеров;
- Автоматические сканирования;
- Анализ данных;
- Определение «узких мест» ресурса;
- Ручной анализ;
- Сбор и анализ полученной информации;
- Анализ векторов атаки;
- Подтверждение полученных векторов;
- Составление отчета.

В заключении

Полученные векторы анализируются и проверяются, фиксируется время обнаружения, поскольку не исключены моменты обнаружения аномальной активности персоналом заказчика путем анализа, к примеру, access log и реализации мер по оперативному устранению уязвимости или атаки.

Данные агрегируются в системы для анализа и оптимизации полученной информации. На основании полученных данных формируется отчет, распределенный по уязвимым сервисам, с детальным описанием уязвимостей, сценариями атаки, состоящими из нескольких векторов, оценкой рисков и рекомендациями по их устранению.

Только при полном и ответственном аудите заказчик получает максимально реалистичную картину зрелости системы информационной безопасности своего веб-сайта.